

CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA - CEFET/RJ *CAMPUS* PETRÓPOLIS
CURSO: BACHARELADO EM ENGENHARIA DE COMPUTAÇÃO

IDENTIFICAÇÃO DE ATAQUES DE PHISHING ATRAVÉS DE MACHINE LEARNING

Bianca Domingos Guarizi

PETRÓPOLIS
2025

CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA - CEFET/RJ *CAMPUS* PETRÓPOLIS
CURSO: BACHARELADO EM ENGENHARIA DE COMPUTAÇÃO

IDENTIFICAÇÃO DE ATAQUES DE PHISHING ATRAVÉS DE MACHINE LEARNING

Bianca Domingos Guarizi

Trabalho de Conclusão de Curso apresentado ao CEFET/RJ - *campus* Petrópolis, como parte dos requisitos para obtenção do título de Bacharel em Engenharia de Computação.

Orientador: Prof. Dalbert Matos Mascarenhas

PETRÓPOLIS
2025

Autorizo a reprodução e divulgação total ou parcial deste trabalho, por qualquer meio eletrônico ou convencional, para fins de estudo e pesquisa, desde que citada a fonte.

Cefet/RJ – Sistema de Bibliotecas / Uned Petrópolis

G915i Guarizi, Bianca Domingos

Identificação de ataques de phishing através de machine learning / Bianca Domingos Guarizi. - 2025.

35f., il.

Trabalho de conclusão de curso (Curso de Bacharelado em Engenharia de Computação) – Centro Federal de Educação Tecnológica Celso Suckow da Fonseca, Petrópolis (RJ), 2025.

Bibliografia: p. 33 - 35.

Orientador: Prof. Dr. Dalbert Matos Mascarenhas

1. Internet (Redes de computação) - Medidas de segurança. 2. Aprendizado de máquina. 3. Random Forest. 4. Phishing. 5. Coronavírus. 6. Monografia. I. Mascarenhas, Dalbert Matos. (Orient.). II. Título.

CDD 005.8

Elaborada por Luciana de Souza Castro CRB7/ 4812

CEFET/RJ
campus Petrópolis

CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA - CEFET/RJ *CAMPUS* PETRÓPOLIS
CURSO: BACHARELADO EM ENGENHARIA DE COMPUTAÇÃO

FOLHA DE APROVAÇÃO

IDENTIFICAÇÃO DE ATAQUES DE PHISHING ATRAVÉS DE MACHINE LEARNING

Bianca Domingos Guarizi

Trabalho de Conclusão de Curso apresentado ao CEFET/RJ - *campus* Petrópolis, como parte dos requisitos para obtenção do título de Bacharel em Engenharia de Computação.

Orientador: Prof. Dalbert Matos Mascarenhas

Aprovado por:

gov.br Documento assinado digitalmente
DALBERT MATOS MASCARENHAS
Data: 20/02/2025 19:23:10-0300
Verifique em https://validar.iti.gov.br

Prof. Dalbert Matos Mascarenhas, D. Sc. (Orientador)

gov.br Documento assinado digitalmente
IGOR MONTEIRO MORAES
Data: 21/02/2025 16:10:53-0300
Verifique em https://validar.iti.gov.br

Prof. Igor Monteiro Moraes, D. Sc.

Prof. Rafael Saraiva Campos, D. Sc.

gov.br Documento assinado digitalmente
RAFAEL SARAIVA CAMPOS
Data: 23/02/2025 23:16:02-0300
Verifique em https://validar.iti.gov.br

Fevereiro de 2025

DEDICATÓRIA

Dedico este trabalho à minha mãe e ao meu pai, que são minha base e minha inspiração. Vocês me ensinaram, com suas vidas, o que é persistência, garra e determinação. Cada desafio que enfrentaram me mostrou que nunca devemos desistir. Este trabalho é também de vocês.

AGRADECIMENTO

Agradeço ao meu orientador, Dalbert Matos Mascarenhas, por acreditar nessa ideia desde o início e por estar ao meu lado em cada etapa deste trabalho. E à minha família, meu profundo agradecimento pelo amor incondicional e pelo apoio constante, sem vocês não teria sido possível chegar até aqui.

RESUMO

Após a popularização de golpes de *phishing*, ataques desse tipo vêm se tornando cada vez mais sofisticados e, com isso, tem aumentado a dificuldade dos usuários em identificá-los. Estes golpes se tornaram ainda mais comuns com a chegada da pandemia do Coronavírus, por este motivo se faz cada vez mais importante a existência de ferramentas e tecnologias que alertem e protejam os usuários contra possíveis golpes. Este trabalho propõe a elaboração de uma ferramenta baseada em um modelo de Aprendizado de Máquina que realiza a análise do tráfego do usuário através do navegador, executando a identificação de possíveis sites de *phishing* e emitindo alertas. O modelo utilizado no presente trabalho é o *Random Forest*, tendo sido obtido como resultado mais satisfatório uma precisão de 99,58%, *recall* de 99,2%, F1 *score* de 99,39% e acurácia de 99,38%.

Palavras-Chave: Segurança, Aprendizado de máquina, Random Forest, Phishing, Detecção de páginas fraudulentas

ABSTRACT

Since the popularity of phishing scams, these attacks have become more sophisticated and harder for users to identify. With the advent of the coronavirus pandemic, these scams have become even more prevalent, making it increasingly important to have tools and technologies that can warn and protect users from possible scams. This work proposes the development of a tool based on a machine learning model that analyses user traffic through the browser, identifies possible phishing sites and issues warnings. The model used in this work is Random Forest and the most satisfactory results were 99.58% accuracy, 99.2% recall, 99.39% F1 score and 99.38% precision.

Palavras-Chave: Security, Machine learning, Random Forest, Phishing, Fraudulent page detection

LISTA DE FIGURAS

1 Triângulo CIA 6
2 Ataques de *phishing* no terceiro trimestre de 2024 12
3 Ataques de *phishing* reportados entre o terceiro trimestre de 2022 até o terceiro trimestre de 2024 13
4 Fluxograma das funcionalidades e componentes da ferramenta 24
5 Exemplo de mensagem retornada pela ferramenta em classificações legítimas 25
6 Exemplo de mensagem retornada pela ferramenta em classificações fraudulentas . . . 25
7 Validação Cruzada 28
8 Coeficiente de correlação 29
9 Validação Cruzada sem os atributos A3, A5 e A10 29

LISTA DE TABELAS

1 Resultados obtidos com todos os atributos coletados 27
2 Resultados obtidos com a remoção dos atributos A3, A5 e A10 28
3 Comparação dos melhores resultados com trabalhos relacionados 29
4 Resultados obtidos na primeira versão da ferramenta 30
5 Comparação dos resultados da V1 e V2 da ferramenta 31

Lista de Siglas

TCC	-	Trabalho de Conclusão de Curso
CEFET	-	Centro Federal de Educação Tecnológica
IP	-	Internet Protocol
DNS	-	Domain Name System
HTML	-	HyperText Markup Language
HTTP	-	Hypertext Transfer Protocol
HTTPS	-	HyperText Transfer Protocol Secure
SSL	-	Secure Sockets Laye
TLS	-	Transport Layer Security
TCP	-	Transmission Control Protocol
UDP	-	User Datagram Protocol
URL	-	Uniform Resource Locator
AC	-	Autoridade Certificadora
WWW	-	World Wide Web
ISO	-	International Organization for Standardization
CIA	-	Confidentiality, Integrity and Availability
XSS	-	Cross-Site Scripting
SQL	-	Structured Query Language
APWG	-	Anti-Phishing Working Group
SVM	-	Support-Vector Machine
KNN	-	K-Nearest Neighbors
MLP	-	Multilayer Perceptron
SBSEG	-	Simpósio Brasileiro em Segurança da Informação e Sistemas Computacionais

SUMÁRIO

1 Introdução **1**

1.1 Tema . . . 1
1.2 Justificativa . . . 1
1.3 Delimitação . . . 2
1.4 Objetivos . . . 2
1.5 Metodologia . . . 2
1.6 Outras publicações . . . 3
1.7 Descrição . . . 3

2 Tecnologias e Protocolos para Navegação e Segurança da Informação **4**

2.1 DNS . . . 4
2.2 Certificado SSL . . . 4
2.3 Protocolo HTTP/HTTPS . . . 5
2.4 HTML . . . 5
2.5 PageRank . . . 5
2.6 Segurança da Informação . . . 6

3 Engenharia Social **8**

3.1 Ataques de Engenharia Social . . . 8
3.2 *Phishing* . . . 8
3.3 Tipos de *phishing* . . . 9
3.3.1 *Email Phishing* . . . 9
3.3.2 *Spear Phishing* . . . 9
3.3.3 Whaling . . . 9
3.3.4 *Clone Phishing* . . . 10
3.3.5 Vishing (*Phishing* de Voz) . . . 10
3.3.6 Smishing (SMS *Phishing*) . . . 10
3.3.7 *Search Engine Phishing* . . . 10
3.3.8 *Deceptive Phishing* . . . 10
3.3.9 Pharming . . . 11
3.3.10 Pop-up *Phishing* . . . 11
3.3.11 *Social Media Phishing* . . . 11
3.4 Notificações de *phishing* . . . 11
3.5 Formas de detecção . . . 12
3.5.1 Blacklists . . . 12

3.5.2 Baseadas em heurística . . . 12
3.5.3 *Machine Learning* . . . 13

4 Aprendizado de Máquina **14**
4.1 Definição . . . 14
4.2 Tipos . . . 15
4.2.1 Aprendizado supervisionado . . . 15
4.2.2 Aprendizado não-supervisionado . . . 15
4.2.3 Aprendizado por reforço . . . 15
4.2.4 Aprendizado evolutivo . . . 16
4.3 Classificadores baseados em árvore e *Random Forest* . . . 16
4.4 *Overfitting* . . . 17

5 Trabalhos Relacionados **18**
5.1 Análise dos trabalhos . . . 18

6 Solução Desenvolvida **20**
6.1 Base de dados . . . 20
6.2 Atributos . . . 21
6.3 Tecnologias Utilizadas . . . 22
6.4 Ferramenta Desenvolvida . . . 23

7 Resultados **26**
7.1 Critérios utilizados para avaliação . . . 26
7.2 Descrição dos Resultados . . . 26

8 Comparação de versões **30**
8.1 Comparação da versão inicial com a versão atual . . . 30

9 Conclusão **32**

1 Introdução

1.1 Tema

Este trabalho trata da detecção de páginas web utilizadas para aplicação de golpes de *phishing* utilizando aprendizado de máquina. Até os dias atuais, o *phishing* permanece explorando diversos usuários e colaboradores através de engenharia social com o intuito de coletar dados sensíveis ou garantir ganho financeiro diretamente ao atacante. Com o aumento do número de páginas fraudulentas criadas diariamente, faz-se necessária uma solução tecnológica eficaz e automatizada para proteger os usuários e organizações de forma a mitigar esta ameaça.

A relevância do tema abordado se dá ao analisar o impacto financeiro e social gerado por este tipo de ataque. O Instituto Ponemon, juntamente com a empresa ProofPrint, realizou o *The Cost of Phishing Study* em 2015 e 2021 (1), com o intuito de estimar a média anual de custos com ataques de *phishing*, tendo sido identificado que houve um aumento de $3,8 milhões em 2015 para $14,8 milhões em 2021. Desse modo, a elaboração de ferramentas automatizadas como a proposta neste trabalho surge como uma resposta proativa para conter o avanço desses ataques, adicionando uma camada de proteção ao ambiente digital.

1.2 Justificativa

A pandemia do coronavírus trouxe mudanças significativas sobre o comportamento digital dos usuários, com uma migração em massa para execução de trabalho remoto, maior uso de serviços e plataformas digitais, além do aumento de compras online. Com a ampliação destes comportamentos, os atacantes aproveitaram para lançar ainda mais ataques de *phishing*, contribuindo para o aumento de crimes cibernéticos (2, 3). Além disso, estudos apontam que durante o período de pandemia houve um aumento de 2000% de atividades maliciosas (4). Este aumento também fez com que os atacantes aplicassem ataques cada vez mais elaborados para garantir que mais usuários se tornassem vítimas, de modo que ficou ainda mais difícil identificá-los.

A crescente sofisticação de golpes de *phishing*, somado ao elevado consumo da internet, fez com que a identificação deste tipo de ataque se tornasse um desafio constante. Métodos tradicionais já existentes, como listas negras (*blacklists*), tornaram-se limitados em relação ao tempo de atualização e adaptação às novas técnicas implementadas nos golpes. O trabalho aqui apresentado justifica-se pela identificação da necessidade de criação de uma ferramenta que seja capaz de analisar padrões nas páginas web em tempo real que diferenciem páginas legítimas de páginas maliciosas, classificando-as com alta precisão, proporcionando um fortalecimento da cibersegurança e a proteção dos dados dos usuários.

1.3 Delimitação

Este projeto se propõe ao desenvolvimento de um modelo de aprendizado de máquina supervisionado com base no algoritmo *Random Forest*, além de um módulo que atua como uma extensão de navegador que coleta as URLs que são acessadas pelo usuário para a execução da classificação. Juntos, o modelo e a extensão formam uma ferramenta funcional a ser utilizada pelo usuário durante sua navegação na internet.

O escopo do trabalho abrange a detecção de páginas web criadas para golpes de *phishing*, sem incluir diferentes tipos de ataques cibernéticos. A base de dados utilizada é composta por bases públicas disponibilizadas, além da coleta de informações através da técnica de enumeração de domínios, possuindo foco em coletar atributos específicos das URLs e do conteúdo das páginas.

1.4 Objetivos

O presente trabalho tem por objetivo desenvolver uma ferramenta funcional e prática que se utiliza de aprendizado de máquina para identificar páginas web elaboradas para execução de ataques de *phishing*. Para isso, utiliza *Random Forest*, que se integra com um módulo para extensão de navegador para coletar as URLs acessadas pelo usuário e realizar as devidas classificações.

1.5 Metodologia

Inicialmente, é realizada uma pesquisa sobre bases de dados públicas que contenham informações sobre URLs utilizadas para *phishing* e URLs determinadas como legítimas. Para dados de *phishing* foram utilizadas as bases de dados PhishTank (5) e OpenPhish (6), disponibilizadas publicamente, tendo sido coletadas suas listagens de URLs gratuitas. No caso das URLs legítimas, foram coletadas as URLs do site Moz, o qual disponibiliza os 500 websites mais populares do mundo com base na Autoridade de Domínio (7).

Assim que estes dados são coletados, são armazenados para pré-processamento, porém, no caso das URLs legítimas, ainda há um passo anterior, sendo utilizada a técnica de enumeração de domínios para ampliar a quantidade de URLs coletadas (de modo a ser uma quantidade mais próxima à quantidade coletada nas bases de dados de *phishing*) e ainda garantir que são URLs de fato legítimas, sem ter a possibilidade de corromper a parte legítima com dados maliciosos. Para isso, a ferramenta WayBack Urls foi utilizada (8).

Na sequência, o pré-processamento é iniciado para identificar dados descartáveis e executar a coleta dos atributos escolhidos através da análise das URLs e das informações sobre os domínios e páginas; para tal, a linguagem de programação Python foi escolhida para uso de suas bibliotecas. Após o modelo *Random Forest* ter sido definido, este é treinado e testado com os dados coletados anteriormente. Por fim, é realizada a criação da extensão para navegador que fará a coleta das URLs

acessadas utilizando a linguagem de programação JavaScript, de forma que se integre com o modelo para execução das classificações.

1.6 Outras publicações

Foi desenvolvida uma versão inicial do presente trabalho, a qual foi publicada no Simpósio Brasileiro em Segurança da Informação e Sistemas Computacionais (SBSeg) no ano de 2024 (9). Essa versão preliminar teve como objetivo também apresentar a ferramenta final desenvolvida; no entanto, as métricas de desempenho alcançadas nesta primeira versão, embora promissoras, não foram tão robustas quanto as observadas na versão atual do trabalho. Isso se deve ao refinamento dos hiperparâmetros do modelo proposto, que foi aprimorado após uma análise mais detalhada e sistemática, permitindo uma otimização significativa do desempenho geral.

O Capítulo 8 deste trabalho faz uma comparação abrangente entre as duas versões, destacando não apenas as melhorias nas métricas, mas também as mudanças técnicas que contribuíram para esses avanços, incluindo uma discussão detalhada sobre as mudanças realizadas na definição dos hiperparâmetros.

1.7 Descrição

As partes subsequentes deste trabalho são divididas em 7 capítulos. O capítulo 2 trata sobre protocolos e tecnologias de navegação na internet que são importantes para entender informações utilizadas na elaboração da ferramenta, como DNS, IP, certificado SSL, entre outros, além de também dar uma breve introdução sobre conceitos de segurança da informação. O capítulo 3 trata sobre engenharia social, descrevendo esse tipo de ataque e chegando à definição do que são ataques de *phishing*.

O capítulo 4 traz informações sobre aprendizado de máquina, seus tipos e descrições sobre o que é e como são implementados modelos *Random Forest*. O capítulo 5 descreve trabalhos relacionados e seus resultados. O capítulo 6 descreve toda a solução desenvolvida, desde a elaboração da base de dados até a ferramenta final desenvolvida. O capítulo 7 trata dos resultados obtidos, comparando com resultados encontrados em trabalhos relacionados. Por fim, o capítulo 8 descreve as conclusões e abordagens para trabalhos futuros.

2 Tecnologias e Protocolos para Navegação e Segurança da Informação

Este capítulo descreve as tecnologias relacionadas a redes de computadores, envolvidas no desenvolvimento do trabalho. A seção 2.1 trata sobre o protocolo DNS e como funciona. A seção 2.2 descreve o certificado SSL que é utilizado pelas páginas web, enquanto a seção 2.3 complementa com a descrição do protocolo HTTP e HTTPS. A seção 2.4 trata sobre a linguagem HTML usada para o desenvolvimento das páginas web. A seção 2.5 descreve o algoritmo de PageRank usado para ranqueamento das páginas e, por fim, a seção 2.6 trata dos fundamentos de segurança da informação.

2.1 DNS

O endereço IP é utilizado para identificação e comunicação entre dispositivos em uma rede, porém, não é tão fácil lembrar do endereço correspondente a cada host que se deseja acessar, uma vez que tem uma configuração numérica mais complexa.

Para suprir a necessidade de lembrar de cada endereço IP, o DNS (Domain Name System) foi desenvolvido. DNS é um sistema distribuído que tem como objetivo traduzir um nome de domínio (google.com, por exemplo), em seu endereço IP correspondente (142.251.32.46).

2.2 Certificado SSL

O certificado SSL (Secure Sockets Layer) é um arquivo digital que tem por objetivo autenticar a identidade de uma página web, habilitando a criptografia nas informações transmitidas entre ele e o navegador. Ele utiliza a tecnologia SSL/TLS (Transport Layer Security) para estabelecer uma conexão segura, protegendo os dados contra interceptações ou alterações durante o tráfego pela rede.

O certificado SSL de uma página web é emitido por uma AC (Autoridade Certificadora), podendo ser necessário um pagamento para executar esta emissão, dependendo do tempo de validade e da AC. Esse certificado contém informações importantes, como o nome do domínio, o nome da entidade (pessoa ou organização), a AC emissora, o período de validade, além da chave pública usada para a criptografia. A chave pública é parte de um par de chaves assimétricas, onde a chave privada correspondente é mantida em segredo pelo servidor.

Assim que um navegador tenta se conectar com um site protegido por este certificado, ocorre um processo de handshake, onde o servidor apresenta seu certificado e o navegador valida a autenticidade do mesmo verificando se foi emitido por uma AC confiável e se ainda está dentro do tempo de validade. Após a validação, as chaves são trocadas para estabelecer uma sessão criptografada. Essa tecnologia é indicada pelo uso de “https://“ na URL e por um ícone de cadeado no navegador.

2.3 Protocolo HTTP/HTTPS

O HTTP (Hypertext Transfer Protocol) é um protocolo onde cada requisição feita por um navegador ao servidor é independente da outra, chamado de sem estado; porém, sua confiabilidade de transmissão é feita através do protocolo TCP. Este foi feito para transferir páginas em HTML (HyperText Markup Language), porém também é utilizado para enviar e receber outros tipos de dados (imagens, vídeos, arquivos); além disso, ele é o protocolo mais básico da WWW (World Wide Web) (10).

O HTTP não oferece suporte para autenticação de identidade, o que significa que não é possível garantir que o servidor a ser acessado é legítimo, além de que não possui criptografia, o que faz com que os dados trafegados não estejam seguros. Para mitigar estes problemas, o HTTPS (HyperText Transfer Protocol Secure) foi desenvolvido.

O HTTPS é uma versão segura do HTTP, este também tem o objetivo de transferir páginas HTML e outros tipos de dados, porém utiliza criptografia através da implementação de certificado SSL. Este tem por objetivo garantir a segurança na transmissão de dados entre o navegador e o servidor, garantindo que dados sensíveis ou informações sigilosas se mantenham protegidas contra ataques (11).

2.4 HTML

O HTML é uma linguagem de marcação utilizada para estruturar e apresentar o conteúdo das páginas web. Através do uso de elementos específicos da linguagem, é possível definir a estrutura e o layout da página que desejar, podendo ser inseridos conteúdos textuais, imagens, documentos e outros elementos que se deseje.

Os elementos específicos que esta linguagem possui são chamados de “tags“, que indicam para o navegador como e qual conteúdo deve ser exibido. Como descrito, essas tags podem ser usadas para formatar texto, inserir imagens, criar links, tabelas, listas, entre outros. Além disso, também podem ser integradas com outras tecnologias para melhorar a usabilidade e o estilo das páginas.

2.5 PageRank

PageRank é um algoritmo utilizado para classificar páginas web com base em sua relevância, sendo amplamente utilizado por motores de busca (como o Google) para classificar a ordem em que as páginas são retornadas quando uma busca é iniciada por um usuário. Sendo assim, cada página recebe um valor que descreve a sua relevância em relação a outras páginas.

Para o presente trabalho, o algoritmo de PageRank utilizado é o disponibilizado pela DomCop, chamado Open PageRank (12), uma iniciativa criada com o intuito de retomar o uso desse tipo de métrica (uma vez que o Google e outros vetores de busca tornaram seus algoritmos privados e não os disponibilizam mais), com o uso de Código Aberto.

2.6 Segurança da Informação

A ISO 27000:2018, que é um conjunto de normas amplamente utilizado para garantia da segurança da informação e proteção dos dados pelas organizações, define segurança da informação da seguinte forma: “A segurança da informação garante a confidencialidade, a disponibilidade e a integridade das informações. Ela envolve a aplicação e o gerenciamento de controles adequados que envolvem a consideração de uma ampla gama de ameaças, com o objetivo de garantir o sucesso e a continuidade sustentados dos negócios e minimizar as consequências dos incidentes de segurança da informação.“ (13)

De forma geral, é possível determinar que a segurança da informação tem como objetivo garantir a segurança das informações, através de controles estabelecidos que ajudam a manter a proteção dos dados. Como a definição aponta, a segurança da informação visa garantir a confidencialidade, a disponibilidade e a integridade, que são os 3 pilares da segurança, referenciados como o triângulo CIA (Confidentiality, Integrity and Availability) visto na Figura 1.

- Confidencialidade: Este pilar tem como foco garantir que dados sensíveis e pessoais sejam mantidos confidenciais, ou seja, apenas pessoas ou processos autorizados terão acesso àquela informação, sem acessos indevidos;

- Disponibilidade: Este tem como objetivo garantir que a informação esteja sempre disponível para aqueles que têm autorização para acessá-la, de modo que possa ser acessada e utilizada sempre que se faça necessário;

- Integridade: Este pilar visa garantir que as informações se mantenham íntegras, sem modificações não autorizadas, garantindo a exatidão dos dados.

Figura 1: Triângulo CIA



Fonte: O Autor (2025)

Para gerenciar a segurança da informação e garantir a proteção dos dados, diversas formas de proteção devem ser empregadas. Alguns tipos de proteção existentes são:

- Proteção Física: Onde são implementados controles de acesso físico a ambientes que armazenem dados sensíveis;
- Proteção lógica: Com a implementação de controles como autenticação, autorização, criptografia, entre outros;
- Treinamento e conscientização: Que consiste em treinamentos regulares para indivíduos sobre boas práticas de segurança, como identificar fraudes, etc.

Atualmente, com o crescimento dos ataques de phishing e a sofisticação que tem-se utilizado para criação dos mesmos, apenas implementar medidas de treinamento e conscientização já não se faz suficiente, uma vez que um usuário sozinho pode não ser capaz de identificar páginas fraudulentas apenas com análises visuais. Desse modo, faz-se necessário a implementação de proteções lógicas que possam auxiliar o usuário nesta detecção.

3 Engenharia Social

Este capítulo se aprofunda em o que é e como são feitos ataques de engenharia social. A seção 3.1 descreve o que são estes ataques e como um atacante age. A seção 3.2 descreve o que é o ataque de *phishing*, seguida da seção 3.3 que explora os tipos de ataques de *phishing* existentes. A seção 3.4 traz um parecer sobre a quantidade de notificações de *phishing* feitas trimestralmente no mundo e a seção 3.5 encerra com meios utilizados para detecção deste tipo de ataque.

3.1 Ataques de Engenharia Social

De acordo com MITNICK *et al.* (14):

> "A engenharia social usa a influência e a persuasão para enganar as pessoas e convencê-las de que o engenheiro social é alguém que na verdade não é, ou pela manipulação. Como resultado, o engenheiro social pode aproveitar-se das pessoas para obter informações com ou sem o uso da tecnologia."

Em (15), ao descrever o perfil de um engenheiro social, destaca que este geralmente possui um perfil agradável, que cativa as pessoas, sendo simpático e carismático, além de criativo e flexível, envolvendo a vítima com conversas agradáveis.

Além destas características, estes perfis também sabem ser bastante flexíveis, de modo a evocar sentimentos de compaixão, ansiedade ou até medo a fim de guiar a vítima a entregar-lhes a informação ou a coisa que desejam. Com isso, entende-se que a engenharia social é um tipo de ataque que se aproveita de vulnerabilidades humanas, focando em explorar fraquezas no comportamento humano, como confiança, medo, curiosidade ou pressa, com o intuito de levar a vítima a acreditar naquilo que o atacante deseja.

Esses fatores tornam a engenharia social particularmente perigosa e podem gerar diversos prejuízos às vítimas, como perda financeira, quando compram algum produto falso ou entregam dados bancários, ou perda de privacidade, quando o atacante consegue adquirir informações sensíveis, como credenciais de acesso ou dados pessoais que podem gerar roubo de identidade.

3.2 *Phishing*

O *phishing* é um tipo de ataque que se utiliza da engenharia social para obter êxito em seus objetivos, consistindo no envio de mensagens fraudulentas, podendo ser por e-mail, SMS, WhatsApp, entre outros, que aparentam ser de uma fonte confiável, como bancos ou empresas conhecidas, com o intuito de levar a vítima a fornecer informações sensíveis, como senhas ou números de cartão de crédito.

Em OLIVO (16) é descrito que o ataque de *phishing* pode chegar à vítima de diferentes maneiras, e geralmente se faz por algum tipo de mensagem ou texto que convence a vítima a clicar em

algum elemento que poderá instalar um malware em seu dispositivo ou irá redirecioná-la para um site fraudulento.

3.3 Tipos de *phishing*

Ataques de *phishing* podem ser realizados de diferentes formas, com diferentes vetores de ataque, em NADEEM *et al.* (17) são pontuados os seguintes tipos de *phishing*:

3.3.1 *Email Phishing*

Este, que é o tipo de *phishing* mais comumente executado de acordo com NADEEM *et al.*, consiste no envio de mensagens através de e-mail com o intuito de se passar por instituições ou pessoas reais para ganhar credibilidade com a vítima e fazê-la acreditar na fraude. Geralmente, os atacantes utilizam os padrões de e-mails reais utilizados por bancos ou outras instituições para fazer com que o e-mail pareça legítimo, com logotipos, formatação e linguagem convincentes; entretanto, este contém um link que irá redirecionar o usuário para a página fraudulenta desenvolvida pelo atacante e irá persuadir o usuário a disponibilizar alguma informação pessoal ou sensível.

Geralmente este tipo de e-mail reproduz alguma sensação de urgência ao usuário, fazendo com que não tenha tempo de analisar a possibilidade de uma mensagem fraudulenta e acabe rapidamente disponibilizando as informações solicitadas.

3.3.2 *Spear Phishing*

O *Spear Phishing* também é relacionado ao envio de e-mails para persuadir a vítima, contudo, este tem um caráter mais direcionado de modo que o atacante pesquisa sua vítima para que possa elaborar um *phishing* personalizado que possui maior possibilidade de ser convertido em sucesso para o atacante. Neste tipo, o e-mail é criado para um alvo específico, de modo que não é realizado um envio em massa, mas sim um envio apenas para um usuário ou organização.

3.3.3 Whaling

Os *phishings* do tipo whaling têm como foco atacar indivíduos do alto escalão, como executivos, CEOs, diretores, entre outros. Neste caso, os atacantes focam em desenvolver narrativas ainda mais elaboradas, já que este tipo de vítima tem menor possibilidade de cair, uma vez que, geralmente, já passaram por treinamentos de conscientização sobre o tema. Ainda assim, mesmo possuindo maior dificuldade de obter sucesso, este tipo de *phishing* é bastante visado, pois esses indivíduos geralmente possuem informações ainda mais importantes, como credenciais de acesso administrativo e até podem gerar maior lucro financeiro ao atacante.

3.3.4 *Clone Phishing*

Neste tipo de *phishing*, de alguma forma, o atacante possui acesso aos e-mails recebidos pela vítima, podendo ser através de um malware instalado ou um man in the middle, de forma que ele replica/clona um e-mail previamente enviado para a caixa de entrada da vítima, modificando documentos em anexo ou links de acesso no corpo do e-mail e os reenviando de um remetente fraudulento alegando um erro no e-mail anterior, devendo ser descartado. Ao acessar o link ou o documento em anexo adulterado, a vítima é afetada de alguma forma, seja pela instalação de algum malware em seu dispositivo ou pelo redirecionamento para uma página fraudulenta.

3.3.5 Vishing (*Phishing* de Voz)

Este tipo se utiliza de chamadas telefônicas, ao invés de mensagens. Neste caso, o atacante pode deixar mensagens de voz solicitando que a vítima ligue de volta para um número específico ou realizar diretamente uma ligação bem-sucedida em que solicita informações sensíveis ao usuário, fingindo se passar por agências bancárias ou empresas que tenham relação com o indivíduo.

3.3.6 Smishing (SMS *Phishing*)

Diferente do e-mail *phishing*, este tipo de ataque visa distribuir mensagens falsas através de SMS; entretanto, tem o mesmo intuito de persuadir a vítima a acessar algum link ou baixar algum conteúdo malicioso para obter algum ganho.

3.3.7 *Search Engine Phishing*

Neste tipo de *phishing* o atacante executa a criação de um site fraudulento que imita uma página legítima que oferece algum serviço real e se utiliza de táticas de otimização para mecanismos de busca que fazem a página fraudulenta aparecer nos primeiros resultados. Assim que o usuário insere suas informações no site fraudulento, o atacante captura seus dados.

3.3.8 *Deceptive Phishing*

Essa é uma das táticas de *phishing* em que o atacante se passa por organizações legítimas, utilizando domínios mais parecidos com a organização real, além de imitar sua identidade visual em e-mails e páginas web para persuadir mais facilmente o usuário. As mensagens geralmente incluem um senso de urgência ou usam táticas de intimidação, como ameaças de desativação de conta ou de acesso indevido, o que estimula a vítima a agir rapidamente.

3.3.9 Pharming

Este tipo de ataque inicialmente explora uma vulnerabilidade existente em uma página web legítima como XSS ou SQL Injection de modo a inserir um redirecionamento para um site malicioso em um botão, página ou em alguma parte do site. Assim que o usuário interage com o elemento modificado, é redirecionado para a página fraudulenta criada pelo atacante sem perceber. Neste caso, geralmente, o atacante desenvolve uma página web parecida com a original, assim tem maior possibilidade de a vítima não perceber que foi redirecionada para um domínio diferente do domínio legítimo.

3.3.10 Pop-up *Phishing*

O Pop-up *Phishing* acontece quando uma janela de pop-up não solicitada ou programada pela página legítima aparece na tela para o usuário enquanto faz sua navegação comum em páginas reais. Estas janelas simulam serviços legítimos e podem solicitar ao usuário a inserção de dados pessoais ou credenciais de login do serviço ao qual estão visitando.

3.3.11 *Social Media Phishing*

Neste tipo de ataque, as redes sociais são utilizadas como vetores de propagação de *phishing*. Os atacantes podem gerar perfis falsos de lojas ou plataformas que solicitam conexão com perfis de usuários comuns para envio de mensagens e links maliciosos. Outra possibilidade é a criação de anúncios falsos que são impulsionados pela rede social como anúncios verídicos; entretanto, possuem links de redirecionamento que levam os usuários a páginas maliciosas que podem persuadir os usuários a compartilhar informações confidenciais ou sensíveis.

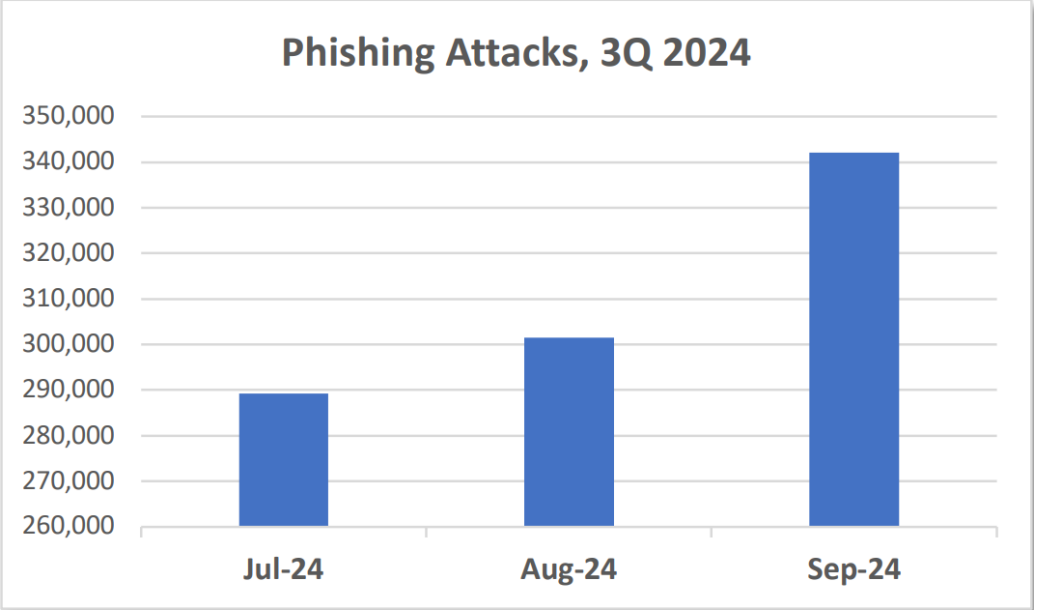
3.4 Notificações de *phishing*

Trimestralmente o APWG disponibiliza o Relatório de Tendências de Atividade de *Phishing* que tem por objetivo analisar o volume de ataques de *phishing* e outras técnicas de roubo de identidade, relatadas ao APWG por suas empresas associadas. Em seu último relatório publicado sobre o terceiro trimestre do ano de 2024 (18), foram relatados 932.923 ataques de *phishing*, como é possível visualizar na Figura 2, estando acima dos 877.536 registrados no segundo trimestre, havendo um aumento de aproximadamente 6,31%.

Além disso, o relatório também relata que as redes sociais foram o alvo mais frequentemente atacado, representando 30,5% de todos os ataques de *phishing*, além de que o Smishing aumentou mais de 22% no terceiro trimestre.

Também é disponibilizado um comparativo da evolução da quantidade de casos observados desde o terceiro trimestre de 2022 até o terceiro trimestre de 2024, sendo possível observar que o período de maior execução de golpes de *phishing* se deu no início do ano de 2023; entretanto, a

Figura 2: Ataques de *phishing* no terceiro trimestre de 2024



Fonte: APWG: *Phishing Activity Trends Report, 3rd Quarter* 2024

quantidade de relatos permanece com um volume bastante considerável, demonstrando como este tema ainda se faz relevante atualmente.

3.5 Formas de detecção

Em LI *et al.* (19), são descritas três formas diferentes utilizadas para detecção de ataques de *phishing*, sendo elas:

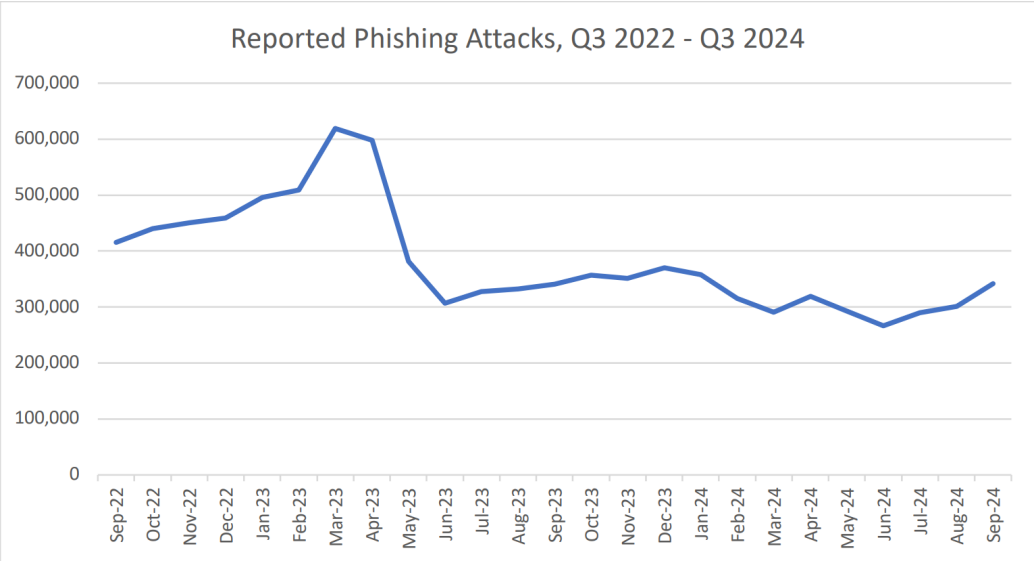
3.5.1 Blacklists

Blacklists ou listas negras são bases de dados que armazenam informações de páginas maliciosas previamente identificadas, neste caso, pessoas interagem com a página, executam o reporte como possível fraude, em seguida uma análise é conduzida e, caso a página seja classificada como fraude, é inserida na blacklist. Esse método exige atualização constante uma vez que novas páginas criadas precisam ser mapeadas, desse modo, estas listas podem ficar rapidamente desatualizadas pois os atacantes mudam frequentemente seus domínios.

3.5.2 Baseadas em heurística

Este método envolve a criação de regras para identificação de tentativas de *phishing*, podendo identificar rapidamente padrões conhecidos de páginas fraudulentas, porém para novos ataques (*zero-day*) pode-se não ter sucesso na identificação. A heurística comum realiza a verificação de padrões de

Figura 3: Ataques de *phishing* reportados entre o terceiro trimestre de 2022 até o terceiro trimestre de 2024



Fonte: APWG: *Phishing Activity Trends Report, 3rd Quarter* 2024

URL suspeitos, identificação de palavras-chave comuns e análise de cabeçalhos de e-mail em busca de anomalias.

3.5.3 *Machine Learning*

Machine Learning ou Aprendizado de Máquina é uma técnica que se utiliza de algoritmos como árvores de decisão, máquinas de vetor de suporte (SVM) e redes neurais para treinamento com características das páginas e URLs conhecidas, e assim executam a detecção de novas páginas. Estes modelos têm facilidade de aprender e se adaptar aos padrões utilizados na criação de páginas de *phishing*, sendo mais promissores na detecção de ataques já conhecidos e ataques *zero-day*.

4 Aprendizado de Máquina

Este capítulo aborda de forma mais detalhada o que é o aprendizado de máquina, além de descrever como funciona o algoritmo de *Random Forest*. A seção 4.1 define o que é o aprendizado de máquina. A seção 4.2 pontua os tipos de aprendizado existentes. A seção 4.3 descreve classificadores baseados em árvore, explorando o *Random Forest*. Por fim, a seção 4.4 descreve sobre o que é *overfitting*.

4.1 Definição

A inteligência artificial é uma ciência que surgiu após a Segunda Guerra Mundial e tem por objetivo automatizar tarefas intelectuais realizadas por seres humanos, desse modo se torna um estudo relevante para qualquer área de atividade humana, como detalhado em (20). A inteligência artificial abrange uma grande variedade de subcampos, sendo um deles o aprendizado de máquina.

O aprendizado de máquina é uma área que visa desenvolver algoritmos que tenham capacidade de aprender a executar uma tarefa com base em sua experiência com a mesma, o que gera algoritmos que conseguem aprender sem interferência humana, apenas baseados em experiências passadas. Em (21) é descrito sobre o aprendizado de máquina que: "Trata-se de uma área de pesquisa multidisciplinar que engloba inteligência artificial, probabilidade e estatística, teoria da complexidade computacional, teoria da informação, filosofia, psicologia, neurobiologia, entre outros."

Ainda em (21) é mencionado sobre existirem dois tipos de tarefas executadas em algoritmos de aprendizado de máquina: tarefas descritivas e tarefas preditivas. As tarefas descritivas têm o objetivo de identificar padrões/relações em dados existentes; estas ajudam a entender o comportamento ou estrutura dos dados analisados. Alguns exemplos de tarefas descritivas são o agrupamento, que visa identificar grupos distintos em dados, separando-os de acordo com características semelhantes, e a análise de associação, que busca descobrir padrões frequentes entre itens, o que ajuda a entender mais sobre o padrão de comportamento dos dados.

Enquanto as tarefas preditivas focam em prever valores ou características futuras com base em informações do passado, existem tarefas de classificação, que buscam identificar a classe ou categoria correspondente para o dado, e regressão, que visa prever o valor de uma determinada variável com base em outras características.

Em (22), são definidas seis etapas no processo de construção de um algoritmo de aprendizado de máquina:

- **Coleta e preparo dos dados:** Etapa de coleta dos dados a serem utilizados no processo de treinamento e teste do modelo, além de execução do preparo analisando os dados para garantir que sejam relevantes para o processo, eliminando, por exemplo, dados nulos.

- **Seleção de atributos:** Neste ponto, são determinados e coletados os atributos mais relevantes

para o processo de aprendizagem do algoritmo, dependendo de um conhecimento prévio do problema para que isto seja identificado.

- **Escolha do algoritmo:** Aqui é realizada a escolha do algoritmo a ser utilizado de acordo com a análise do problema alvo e, caso necessário ou possível, através de trabalhos prévios que abordaram o mesmo problema ou algo semelhante.
- **Seleção do modelo e hiperparâmetros:** Após a escolha do modelo, a seleção de hiperparâmetros é realizada através de conhecimentos prévios sobre o funcionamento do modelo e execução de testes manuais para identificação do que se adequa melhor ao problema.
- **Treinamento:** Este processo realiza a preparação do modelo para executar as análises dos atributos recebidos, com o objetivo de identificar padrões e realizar classificações ou predições. No entanto, ele não necessariamente resulta no modelo final, podendo exigir ajustes subsequentes e a repetição desse mesmo processo para refinamento e otimização.
- **Avaliação:** Processo final de teste do modelo, apresentando ao algoritmo dados sem a resposta correta para identificar como este se aproxima das informações reais após já ter sido treinado.

4.2 Tipos

Em (23) são apresentados 4 tipos de algoritmos de aprendizado de máquina:

4.2.1 Aprendizado supervisionado

O aprendizado supervisionado ocorre quando o conjunto de dados que se tem possui todas as informações de alvo (ou seja, todas as respostas corretas). Desse modo, o algoritmo é apresentado às respostas certas para cada dado de treinamento, com isso generaliza para descobrir as respostas corretas sobre qualquer dado de entrada.

4.2.2 Aprendizado não-supervisionado

Neste caso, as respostas corretas não são apresentadas ao algoritmo; este analisa os dados e identifica padrões e semelhanças entre eles, identificando características em comum que definem categorias iguais.

4.2.3 Aprendizado por reforço

No aprendizado por reforço há uma mescla do aprendizado supervisionado com o não-supervisionado. Neste tipo, o algoritmo recebe a confirmação de sua resposta está ou não correta, porém, no caso de ser incorreta, não recebe informação de como deve corrigi-la, sendo necessário testar diversas respostas para encontrar a correta.

4.2.4 Aprendizado evolutivo

Este tipo de aprendizado tenta simular a evolução biológica, sendo possível entendê-la como um processo de aprendizado, já que os organismos buscam evoluir e se adaptar para melhorar sua taxa de sobrevivência e de seus descendentes.

4.3 Classificadores baseados em árvore e *Random Forest*

Os classificadores baseados em árvore são algoritmos de aprendizado supervisionado que estruturam os dados em uma árvore hierárquica composta pelos seguintes componentes:

- Nó Raiz: Nó inicial que armazena todo o conjunto de dados;
- Nós internos: Nós que representam uma decisão tomada baseada em uma característica específica, contém apenas partes do conjunto total dos dados;
- Nós folhas: Nós que representam o resultado final de classificação, representando os resultados e divisões obtidas;
- Ramos: Parte que conecta um nó com os seguintes.

Para o processo de formação das árvores, o algoritmo leva em consideração o nível de pureza ou homogeneidade das classes nos nós gerados. De forma geral, é medido o aprendizado ou ganho de informação dos atributos para separação dos dados. Para maximizar a pureza ou homogeneidade nos nós gerados, os critérios mais utilizados são o índice Gini e a Entropia.

O índice Gini é definido pela Equação 1, onde P_i é a proporção de amostras da classe i para o nó K. Este índice avalia os atributos selecionados de forma aleatória, escolhendo o que possui maior grau de pureza dentre as amostras. Se o nó K é homogêneo, sua proporção $P_i(K)$ para a classe i é igual a 1, ao passo que o índice é igual a 0; desse modo, quanto menor o índice, maior pureza possui o nó (24).

$$Gini(K) = 1 - \sum_{i=1}^{C} p_i^2 \tag{1}$$

A entropia, também chamada entropia cruzada, é definida pela Equação 2, onde *pi* é a proporção de amostras da classe i para o nó K. Esta mede o grau de impureza ou aleatoriedade do nó. Se todas as amostras de um nó pertencerem a uma classe, a entropia desse conjunto de dados será 0; desse modo, quanto menor a entropia, maior a pureza do nó (ou, menor a impureza) (25).

$$Entropia(K) = -\sum_{i=1}^{C} p_i \log_2(p_i) \tag{2}$$

O *Random Forest* é um algoritmo de aprendizado de máquina baseado em um conjunto de árvores de decisão independentes que vão sendo construídas a partir das ramificações do conjunto de treinamento. De modo mais formal, este é um classificador que consiste em um conjunto de árvores $\{h_k(x, T_k)\}$, onde T_k são amostras aleatórias independentes e distribuídas igualmente, onde cada árvore contribui com um voto para a classe mais popular em x (26).

Este algoritmo usa randomização para criar suas árvores de decisão, de modo que amostras aleatórias dos dados de treinamento são selecionadas, não utilizando a base de dados inteira, aplicando 2 métodos distintos. Para o primeiro processo de randomização, é utilizado o método chamado bootstrap, onde as amostras podem se repetir ao longo da seleção e outras podem não ser selecionadas. O segundo processo de randomização ocorre nos nós de decisão da árvore, onde para cada um seleciona-se aleatoriamente um subconjunto dos atributos de entrada, e então seleciona-se, dentro deste subconjunto, o par atributo-limiar que resulta na melhor divisão (isto é, no maior ganho de informação) (27).

O processo de divisão é feito até que uma condição de parada seja atingida, como não haver mais ganho na divisão ou um tamanho máximo de profundidade da árvore seja atingido, por exemplo. A partir disso, o último nó se torna um nó folha e o caminho do nó raiz até o nó folha contém as características de uma das classes dos dados analisados.

4.4 *Overfitting*

O *overfitting* é uma ocorrência em que um algoritmo é apresentado aos dados de treinamento e se modela de forma a se ajustar completamente para a previsão desses dados, porém, quando apresentado a novos dados (dados separados para teste), não é capaz de fazer uma previsão tão satisfatória, já que seu aprendizado não foi generalizado como o esperado (28).

Esse fenômeno ocorre quando o modelo aprende não apenas os padrões subjacentes dos dados de treinamento, mas também os ruídos e as flutuações aleatórias presentes nesses dados, resultando em uma complexidade excessiva que prejudica sua capacidade de generalização.

O *overfitting* é particularmente problemático em modelos com alta capacidade de aprendizado, como redes neurais profundas ou árvores de decisão com muitos níveis, que possuem flexibilidade suficiente para "memorizar" os dados de treinamento em vez de aprender a generalizar a partir deles. Como consequência, o modelo pode apresentar um desempenho excepcional nos dados de treinamento, com métricas como acurácia ou erro próximas de valores ideais, mas falhar ao ser aplicado a dados não vistos, refletindo uma baixa capacidade de generalização.

5 Trabalhos Relacionados

Este capítulo é composto apenas de uma seção (5.1), a qual descreve os trabalhos relacionados utilizados como base de estudo durante a idealização deste trabalho.

5.1 Análise dos trabalhos

No trabalho SAFI *et al.* é realizada uma análise sobre diferentes técnicas utilizadas para detecção de sites de *phishing*, tendo sido analisados métodos baseados em listas (*blacklists*), similaridade visual, heurística, aprendizado de máquina e aprendizado profundo (29). Os autores analisaram 80 outros trabalhos sobre o assunto, chegando à conclusão de que a técnica mais comumente utilizada é a de aprendizado de máquina, uma vez que é uma das técnicas mais promissoras e que possui os melhores resultados até mesmo na detecção de ataques de *zero-day*. O trabalho pontua ainda que as técnicas de aprendizado profundo também são bastante promissoras, sendo ainda melhores que as de aprendizado de máquina tradicional, porém sendo menos utilizadas.

Já no trabalho Rodrigues *et al.* é realizada a criação de um sistema que utiliza aprendizado de máquina para detecção de *phishing*, tendo sido elaborada uma base de dados de 11.703 páginas para treinamento e 2.023 para teste (30). Durante o processo de criação, os autores realizam testes sobre a base de dados elaborada através da utilização de dois algoritmos: J48 e Random Tree (Árvore Aleatória). Ambos os algoritmos tiveram alta acurácia, tendo sido 94.18% e 93.21%, respectivamente. Logo em seguida, para validação final, foi utilizada a rede neural WiSARD, conseguindo assim um resultado de aproximadamente 81.8%, resultado inferior ao dos primeiros modelos utilizados, porém ainda aceitável, de acordo com os autores.

Em do Rego *et al.* foram utilizados os classificadores SVM, KNN e Regressão Logística para elaboração de um sistema de detecção de *phishing* (31). A base de dados elaborada possui um total de 12.912 páginas no total. O modelo que obteve a maior acurácia foi o SVM, obtendo 95,60%, enquanto o KNN obteve uma acurácia de 93,97% e a Regressão Logística obteve 95,22%.

No trabalho Correia *et al.*, os autores realizaram testes iniciais com 4 classificadores diferentes, sendo eles Árvore de Decisão, Regressão Logística, Máquina de Vetores de Suporte e *Random Forest* (Floresta Aleatória) em uma base de dados com um total de 7120 URLs (32). Após os testes iniciais, foi observado que o algoritmo que obteve melhor desempenho foi o *Random Forest*, obtendo 95,03% de acurácia, tendo sido este escolhido para prosseguir com os testes. Em seguida, os autores realizaram diversos testes utilizando tipos diferentes de normalização, além de remover alguns atributos para verificação do melhor desempenho, que foi obtido através da utilização de todos os atributos coletados e normalização *Z-Score* com acurácia final de 95%.

O trabalho realizado em (22) executou a comparação entre 5 classificadores, sendo eles MLP, SVM, KNN, Árvore de decisão e *Random Forest*. Neste trabalho, uma base de dados contendo 1881 URLs foi desenvolvida. Como resultado inicial, utilizando todos os atributos coletados pelos autores,

o melhor desempenho foi obtido através do classificador *Random Forest*, com acurácia de 99,2%; além disso, testes foram realizados removendo atributos que proporcionavam mais tempo de resposta do algoritmo, desse modo, havendo um melhor desempenho também através do algoritmo *Random Forest* com 96,5%.

O presente trabalho tem como diferencial a elaboração de uma ferramenta funcional que possa ser utilizada pelos usuários durante sua navegação na internet para detecção de possíveis páginas de *phishing*. Com base nos resultados obtidos em (32) e (22), foi selecionado o modelo *Random Forest* para execução da classificação, tendo se demonstrado bastante eficiente na detecção de páginas de *phishing*. Além disso, uma base de dados mais ampla foi utilizada, contendo um total de 50261 URLs.

6 Solução Desenvolvida

Este capítulo descreve detalhadamente a solução desenvolvida no presente trabalho. A seção 6.1 detalha a coleta de dados para criação da base de dados. A seção 6.2 descreve todos os atributos escolhidos para a implementação do classificador. A seção 6.3 descreve as tecnologias utilizadas, enquanto a seção 6.4 trata de como foi feito o desenvolvimento da ferramenta.

6.1 Base de dados

Inicialmente, foi realizada a análise de bases de dados públicas que disponibilizassem informações de URLs de fraude e legítimas já conhecidas, de modo que pudessem ser utilizados dados confiáveis para esta implementação.

Para coleta das URLs de *phishing* utilizadas, foram utilizadas 2 bases de dados: PhishTank (5) e OpenPhish (6), ambas bases existentes há mais de 10 anos no mercado, tendo construído um portfólio de relatos de *phishing* bastante consistente. No caso do OpenPhish, é disponibilizado de forma gratuita um arquivo de texto contendo um total de 500 URLs, enquanto a PhishTank disponibiliza um arquivo CSV com mais de 60 mil entradas de dados.

Na sequência, foi iniciada a busca por URLs legítimas, porém nenhuma base consistente, com dados suficientes e que garantisse confiabilidade na legitimidade dos dados foi encontrada. Desse modo, uma nova abordagem para estes dados foi implementada. Inicialmente, as URLs legítimas foram coletadas a partir da base de dados disponibilizada pelo site Moz (7), que disponibiliza os 500 web sites mais populares com base na Autoridade de Domínio, sendo esta uma pontuação desenvolvida pela empresa Moz que identifica a probabilidade de um site ser classificado nos resultados dos motores de busca, como o Google (33).

Como a amostra disponibilizada pelo site Moz não é tão grande quanto as disponibilizadas pela PhishTank e OpenPhish, foi implementada uma abordagem de enumeração de domínios sobre os dados legítimos coletados. A enumeração de domínios é uma técnica muito utilizada principalmente por profissionais de segurança ofensiva; ela tem por objetivo identificar e mapear subdomínios e URLs específicas ou páginas internas que estão associadas ao domínio principal. Por exemplo, se o domínio principal de uma organização é exemplo.com, a enumeração de domínios busca identificar subdomínios como login.exemplo.com ou admin.exemplo.com; ou seja, esta técnica busca subdomínios no formato *.exemplo.com, ou páginas internas como exemplo.com/produto. Para a implementação da técnica de enumeração de domínios, a ferramenta WayBack Urls (8) foi utilizada; desse modo, foi aplicada esta ferramenta em todas as 500 URLs coletadas através do site Moz e foram selecionados, de forma aleatória, alguns dos resultados retornados pela ferramenta.

Após terem sido realizadas as coletas abrangentes de cada classe de URLs, considerando que algumas URLs poderiam não mais estar ativas, foi necessário filtrar de modo que as URLs já desativadas fossem descartadas; para isso, um código em Python foi criado, utilizando a biblioteca requests

para identificar o retorno da requisição. Sendo um retorno de código positivo (como o 200), a URL era mantida; caso contrário, a mesma seria descartada das análises subsequentes.

No total, foi possível coletar 50261 URLs para a base de dados gerada, tendo sido 27891 URLs de *phishing* e 22370 URLs legítimas. Como era esperado, pela dificuldade de aquisição, as URLs legítimas estão em quantidade menor, compondo aproximadamente 44,5% da base de dados, enquanto as URLs de *phishing* compõem em torno de 55,5%.

6.2 Atributos

Após a coleta e preparo dos dados terem sido realizados, foram iniciadas as análises sobre os atributos que seriam coletados para classificação dos dados. Para isso, foram selecionados 13 atributos, escolhidos com base nos trabalhos relacionados estudados durante o processo e também com base em uma análise manual realizada para identificar diferenças entre páginas de *phishing* e páginas legítimas, sendo os seguintes (9):

- **Tamanho da URL (A1)**: Valor numérico que determina a quantidade de caracteres contidos na URL. Sites maliciosos podem se utilizar de grandes URLs para enganar os usuários e adicionar informações que pareçam legítimas;
- **Utiliza HTTPS (A2)**: Valor booleano (0 ou 1) que determina se a página utiliza protocolo HTTP (sem criptografia) ou HTTPs (com criptografia), algumas páginas de *phishing* ainda utilizam HTTP, sem adicionar certificado SSL às suas páginas;
- **Possui formato IP (A3)**: Valor booleano (0 ou 1) que identifica se a página utiliza formato IP. Algumas páginas de *phishing* não fazem uso de DNS, utilizando diretamente o IP associado;
- **Quantidade de pontos '.' (A4)**: Valor numérico que determina a quantidade de pontos na URL. Páginas de *phishing* podem colocar mais pontos na URL para adicionar subdomínios e parecer mais com URLs legítimas;
- **Contém o caractere '@' (A5)**: Valor booleano (0 ou 1) que determina a existência deste caractere na URL. Este caractere pode ser utilizado para fazer o navegador ignorar toda informação que existe antes dele, de modo que atacantes podem adicionar um domínio real no início para enganar o usuário;
- **Total de dias ativo (A6)**: Valor numérico que determina a quantidade de dias em que o domínio está ativo. Páginas de fraude geralmente são criadas por um curto período de tempo para aplicação do golpe;
- ***PageRank* (A7)**: Valor numérico que determina a classificação da página. Páginas de fraude geralmente possuem baixas classificações já que não são muito acessadas e por não ficarem muito tempo ativas;

- **Possui formulário HTML (A8)**: Valor booleano (0 ou 1) que determina se há presença de formulário HTML na página. Geralmente páginas de *phishing* possuem algum formulário para inserção e captura de dados sensíveis;

- **Validade do Certificado SSL (A9)**: Valor numérico que determina o tempo de validade do certificado SSL da página (caso seja HTTPS). Páginas legítimas costumam utilizar certificados pagos que disponibilizam mais de 1 ano de validade, enquanto páginas de fraude costumam se utilizar de certificados gratuitos, que disponibilizam 3 meses de validade;

- **Contém caracteres '//' (A10)**: Valor booleano (0 ou 1) que determina a existência dos caracteres na URL (excluindo a parte inicial do 'http://' ou 'https://'). Este caractere é utilizado para redirecionar o usuário para a URL inserida após ele;

- **Possui texto 'https' na URL (A11)**: Valor booleano (0 ou 1) que determina a presença de texto 'https' na URL (excluindo a parte inicial do 'http://' ou 'https://'). Esta pode ser uma tática utilizada pelos atacantes para enganar o usuário e fazê-lo pensar que a URL é criptografada quando não é;

- **Possui caractere '-' no domínio (A12)**: Valor booleano (0 ou 1) que determina a presença do caractere na URL. Este pode ser usado para enganar o usuário, sendo utilizado para separar palavras e se assemelhar com domínios legítimos;

- **Possui iframe no código HTML (A13)**: Valor booleano (0 ou 1) que determina a presença da tag iframe na página. Esta tag pode ser utilizada para incorporar uma página real na página fraudulenta de modo a enganar o usuário e parecer estar na página legítima.

As bases de dados coletadas não disponibilizam os atributos descritos, nelas o único dado coletado foi diretamente a URL. Desse modo, a coleta foi feita através da criação de um algoritmo em Python para aquisição destas informações.

6.3 Tecnologias Utilizadas

O classificador foi desenvolvido utilizando a linguagem de programação Python, utilizando-se da biblioteca scikit-learn (34) para criação do modelo *Random Forest*, escolhido devido ao seu desempenho em (32) e (22). A extensão de navegador desenvolvida utiliza a linguagem JavaScript e a comunicação entre o classificador em Python e essa extensão em JavaScript é realizada por um servidor criado com a biblioteca Flask do Python, que gera um ambiente de comunicação e gerencia o envio e recebimento de dados em formato JSON.

6.4 Ferramenta Desenvolvida

A ferramenta desenvolvida neste trabalho é baseada em 2 partes interconectadas: o classificador e uma extensão para o navegador. O classificador *Random Forest* criado foi modelado com os seguintes hiperparâmetros:

- Árvores de decisão = 100 (n_estimators);
- Critério de homogeneidade = 'gini' (criterion);
- Número de recursos considerados na divisão = 'sqrt' (max_features);
- Bootstrap = True (bootstrap);
- Controle da aleatoriedade do modelo = 100 (random_state);
- Valor mínimo de impureza necessário para divisão do nó = 0.00001 (min_impurity_decrease);
- Profundidade máxima da árvore = None (max_depth).

Outros hiperparâmetros foram mantidos com seus valores padrão. Após a modelagem do classificador, este foi conectado à base de dados para iniciar o processo de testes. Para a determinação dos valores acima, foram executados diversos testes variando os valores e opções possíveis, tendo estes retornado os melhores resultados, evitando a possibilidade de *overfitting*.

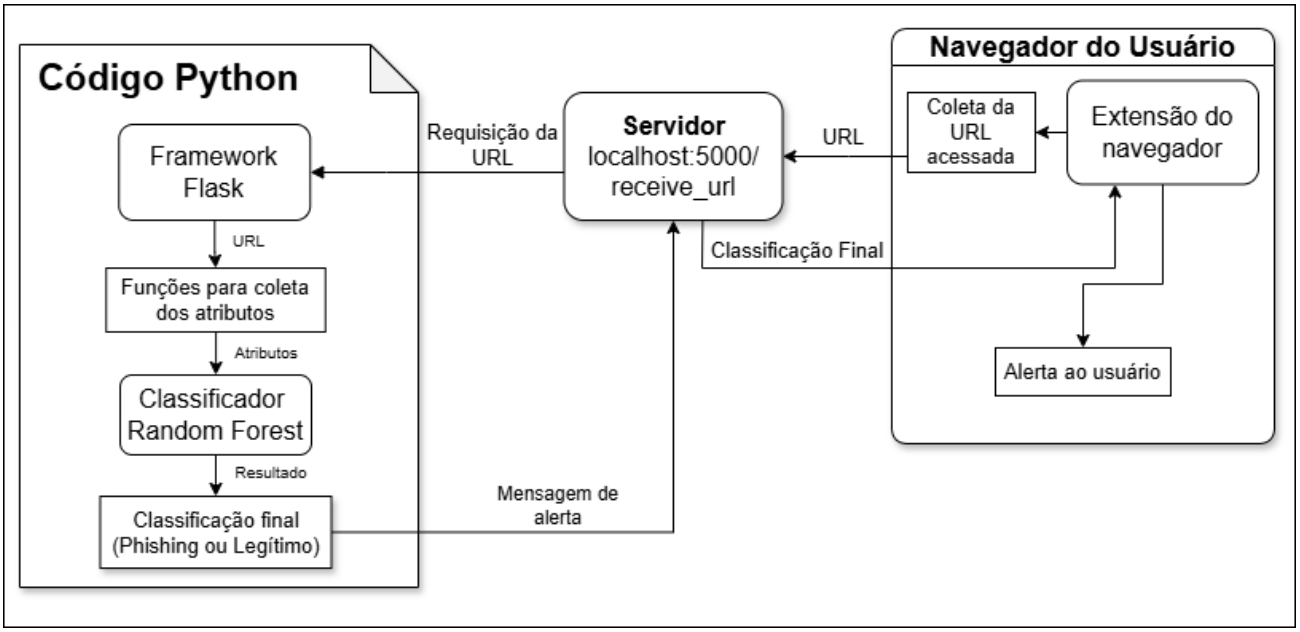
Assim que chegou-se a resultados aceitáveis sobre os critérios de acurácia, precisão e *recall* , o desenvolvimento do código para análise do tráfego em tempo real foi iniciado. Este código possui todas as funções necessárias para coleta dos atributos mencionados anteriormente durante a navegação do usuário. O código implementa funções para análise dos caracteres da URL, coletando tamanho, se é http ou https, se possui formato IP ou usa DNS, entre outros, além de funções para coleta da quantidade de dias que o domínio se encontra ativo (utilizando o serviço WHOIS), o PageRank da página (utilizando o serviço Open PageRank (12)), o tempo de validade do certificado e outras informações.

Na sequência, a extensão para navegador foi desenvolvida em uma versão compatível com o navegador Google Chrome, de modo que, quando instalada corretamente no navegador do usuário, esta coleta a URL que está sendo acessada pelo usuário, envia para o código em Python que contém o classificador e retorna ao usuário a classificação final.

Entretanto, não foi possível estabelecer uma comunicação direta entre a extensão e o código em Python, por isso, um servidor intermediário foi desenvolvido para intermediar esta comunicação. Utilizando o framework Flask (com uma biblioteca Python) um servidor central foi criado, podendo ser acessado através do caminho 'localhost:5000/receive_url'. Sendo assim, o tráfego da informação ocorre de forma que a extensão para o navegador coleta a URL e a envia ao servidor central, que armazena a informação; na sequência, o código em Python solicita ao servidor a informação em formato JSON e extrai o dado da URL acessada.

Com isso, o código em Python aciona o classificador, que executa todo o processamento de coleta de atributos e classificação final da página entre legítimo ou *phishing* e devolve esta informação ao servidor central. Então a extensão solicita a informação ao servidor e mostra a informação ao usuário em formato de alert que é mostrado na tela. Este fluxo de ações de cada parte do código pode ser observado através do fluxograma mostrado na Figura 4.

Figura 4: Fluxograma das funcionalidades e componentes da ferramenta



Fonte: O Autor (2025)

A mensagem que é enviada ao usuário tem por objetivo alertá-lo em caso de perigo, desse modo, a mensagem enviada e, caso de classificação legítima apenas descreve “Navegação Segura“, enquanto a mensagem em caso de *phishing* diz “O site acessado através do link ’http://exemplo.com’ é suspeito. Aconselhamos que não compartilhe dados ou informações sensíveis.“, alertando o usuário do perigo, como mostrado nas Figuras 5 e 6.

Como é possível visualizar nas Figuras 5 e 6, o alerta também retorna o tempo que o classificador levou para executar a análise da URL; isto foi implementado apenas para ter uma visualização inicial do impacto que está sendo gerado sobre a experiência do usuário.

É importante destacar que ao encontrar uma URL potencialmente fraudulenta, a navegação do usuário não é imediatamente interrompida pela ferramenta, sendo de responsabilidade do usuário dar continuidade à navegação mesmo após o alerta ou interromper. Isto foi decidido devido a casos em que haverá classificações falsas positivas e nos casos em que o usuário pode estar acessando uma página que sabe ser fraudulenta, mas está realizando alguma análise sobre a mesma.

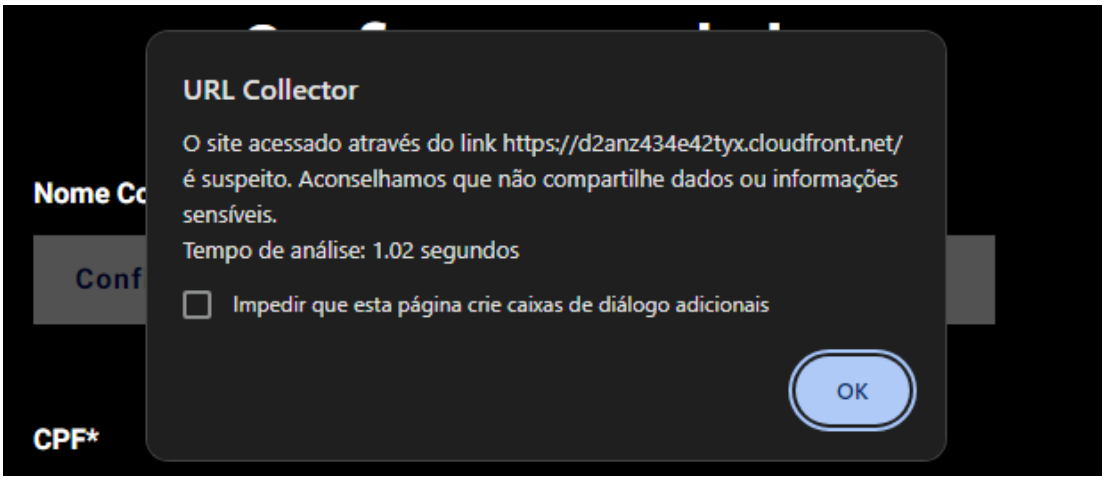
A ferramenta completa está disponível no GitHub, podendo ser acessada em (35) para análise do código e reprodução dos testes aqui apresentados.

Figura 5: Exemplo de mensagem retornada pela ferramenta em classificações legítimas



Fonte: O Autor (2025)

Figura 6: Exemplo de mensagem retornada pela ferramenta em classificações fraudulentas



Fonte: O Autor (2025)

7 Resultados

Este capítulo trata dos resultados obtidos sobre a implementação do classificador *Random Forest*. A seção 7.1 descreve os critérios e métricas utilizados para a avaliação do modelo, enquanto a seção 7.2 detalha todos os resultados obtidos nos testes realizados.

7.1 Critérios utilizados para avaliação

Para formalização dos resultados apresentados, definiu-se que a classe dos sites de *phishing* será indicada aqui como positiva, enquanto os sites legítimos serão indicados como negativos, desse modo, classificações verdadeiras negativas (VNeg) são sites legítimos que foram classificados corretamente como sendo legítimos pelo modelo. Do mesmo modo, verdadeiros positivos (VPos) são sites de *phishing* classificados corretamente como *phishing*. Por outro lado, classificações falsas negativas (FNeg) são sites de *phishing* classificados erroneamente como legítimos e falsos positivos (FPos) são sites legítimos classificados erroneamente como *phishing*.

Para realizar a avaliação final sobre a ferramenta desenvolvida, foram utilizadas 4 métricas: acurácia, precisão, *recall* (sensibilidade) e F1 *score*.

- Acurácia: Mede a proporção de previsões corretas em relação ao total de previsões;

$$Acurácia = \frac{\text{VPos} + \text{VNeg}}{\text{VPos} + \text{VNeg} + \text{FPos} + \text{FNeg}} \tag{3}$$

- Precisão: Indica a proporção de verdadeiros positivos em relação ao total de positivos previstos;

$$Precisão = \frac{\text{VPos}}{\text{VPos} + \text{FPos}} \tag{4}$$

- *Recall*: Indica a proporção de verdadeiros positivos em relação ao total de positivos reais;

$$Recall = \frac{\text{VPos}}{\text{VPos} + \text{FNeg}} \tag{5}$$

- F1 *score*: É a média harmônica entre precisão e *recall*, resumindo ambas as métricas em um único valor.

$$F1 = 2 \times \frac{\text{Precisão} \times recall}{\text{Precisão} + recall} \tag{6}$$

7.2 Descrição dos Resultados

Os resultados obtidos para as métricas descritas anteriormente (acurácia, precisão, *recall* e F1 *score*), são apresentados na Tabela 1. Estes resultados foram obtidos através da separação dos dados de

forma que: 85% dos dados foram utilizados para o treinamento do modelo e os outros 15% para teste, além de serem relacionados à classificação realizada utilizando todos os 13 atributos anteriormente mencionados.

Tabela 1: Resultados obtidos com todos os atributos coletados

	Precisão	***Recall***	**F1 *score***	**Acurácia**
Resultado - Teste	99,64%	99,02%	99,33%	99,40%
Resultado - Treinamento	99,69%	99,41%	99,55%	99,60%

A tabela de resultados apresentada consiste na descrição das métricas tanto para teste quanto para treinamento do modelo, isso porque, foi realizada uma comparação entre estes resultados para verificar a possibilidade de ocorrência de *overfitting* no modelo. Entretanto, o resultado final obtido foi satisfatório, tendo sido aceitável a pequena variação apresentada entre os resultados de teste e treino para assumir a não ocorrência de *overfitting*.

Considerando o pequeno desbalanceamento da base de dados descrito anteriormente, onde é possível identificar que foram coletadas mais páginas de *phishing* do que páginas legítimas, as métricas mais importantes de serem observadas neste caso são a precisão e o *recall* , que obtiveram resultados de teste com 99,64% e 99,02%. Comparando com outros trabalhos que tiveram bons resultados com o uso do *Random Forest* como em (22), este apresentou uma precisão de 99,7% e um *recall* de 99,2%, tendo sido obtido aqui resultados próximos, porém, um pouco abaixo do apresentado, já em relação ao trabalho (32), a precisão e *recall* finais apresentadas foram de 94% e 97%, respectivamente, tendo o presente modelo obtido um resultado mais satisfatório. Relacionado ao F1 *score*, da mesma maneira, houve uma pequena diferença entre os resultados em (22), tendo sido obtido 99,4% e no presente trabalho 99,33%, enquanto em (32) este foi de 95%.

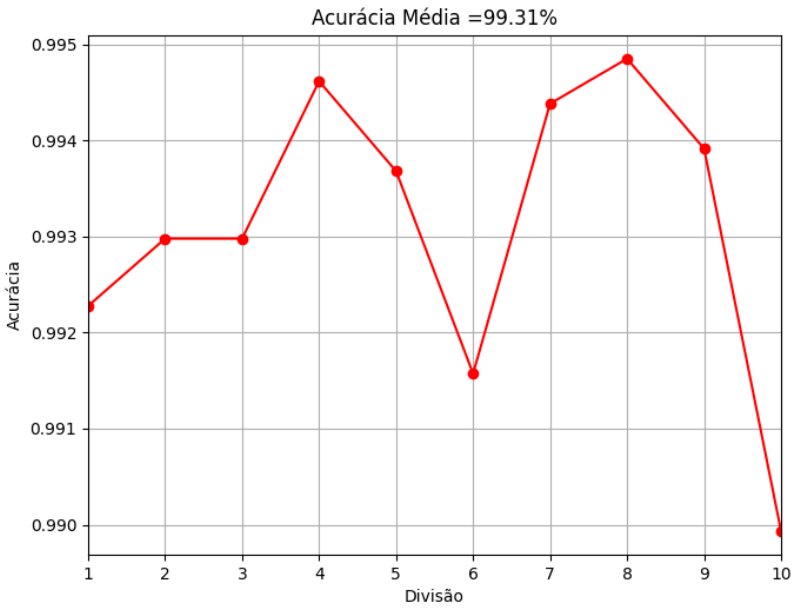
Nota-se que as variações das métricas descritas são pequenas, demonstrando que o resultado obtido neste trabalho é satisfatório considerando o fato de que a base de dados aqui apresentada possui mais de 50 mil URLs em sua totalidade, enquanto em trabalhos como (22) foi utilizada uma base de dados consideravelmente menor, com 1881 URLs e em (32) 7120 URLs.

Ao realizar uma análise da acurácia, é possível visualizar que a tabela apresenta uma acurácia final de 99,40%, sendo esta a acurácia de apenas 1 teste isolado realizado. Desse modo, para obter um resultado mais preciso da acurácia do modelo, foi utilizada a validação cruzada, uma técnica que divide o conjunto de dados em partes distintas, treina o modelo com algumas dessas partes e o testa com as partes restantes. Para a validação cruzada aqui utilizada, os dados foram divididos em 10 partes, retornando 10 resultados que foram utilizados para executar a média e assim obter a acurácia média final. O resultado obtido foi de 99,31%, como pode ser observado na Figura 7.

Este resultado de acurácia média demonstra-se ainda superior ao obtido em (22) e (32), onde a melhor acurácia foi de 99,2% e 95%, respectivamente.

Na sequência, além de ter sido realizada uma análise dos resultados com todos os atributos coletados descritos anteriormente, foi realizada uma verificação sobre a correlação de cada atributo

Figura 7: Validação Cruzada



Fonte: O Autor (2025)

com a saída, sendo representada pela Figura 8.

Com a observação do gráfico demonstrado na Figura 8, foram realizados alguns testes para remoção dos atributos com correlação quase nula para identificar aqueles que poderiam ser removidos sem grande perda de desempenho na classificação do modelo.

Como resultado final, foram removidos os atributos A3, A5 e A10, tendo sido o melhor resultado. Esta remoção resultou em resultados melhores que as análises com todos os atributos, como demonstrado pela Tabela 2, além de caracterizar uma menor complexidade do modelo, uma vez que apenas 10 atributos são utilizados.

Tabela 2: Resultados obtidos com a remoção dos atributos A3, A5 e A10

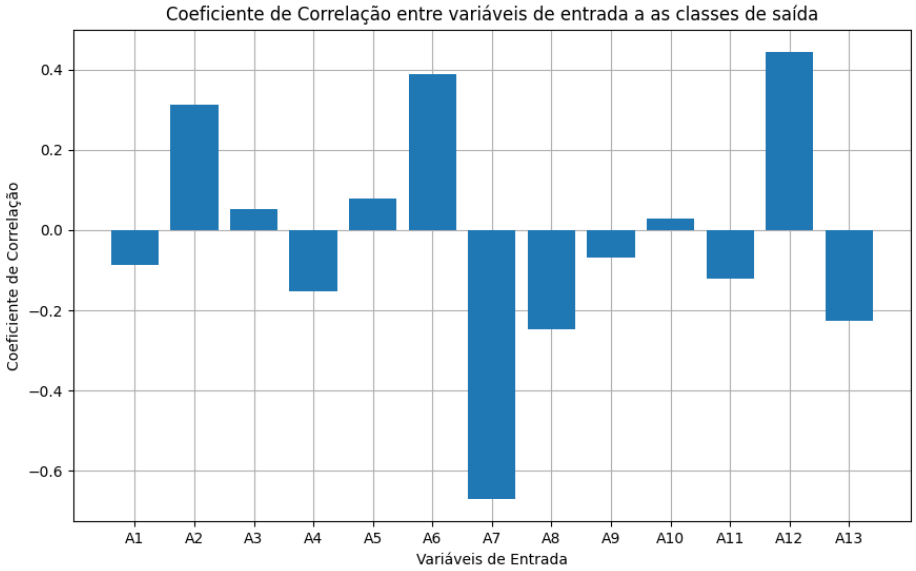
	Precisão	***Recall***	**F1 *score***	**Acurácia**
Resultado - Teste	99,58%	99,20%	99,39%	99,46%

Com isso, uma nova análise de validação cruzada foi realizada, tendo como resultado 99,38% de acurácia média, como pode-se observar na Figura 9, sendo este o resultado final de acurácia utilizado como o melhor resultado obtido através deste trabalho.

Realizando uma nova comparação com os resultados obtidos em (32) e (22), pode-se observar que o resultado final após a remoção destes atributos demonstrou-se ainda bastante satisfatório, como é possível visualizar na Tabela 3.

Os resultados obtidos no presente trabalho ficaram bem próximos dos obtidos no trabalho (22), que foi o trabalho com melhores resultados encontrados durante as pesquisas de trabalhos relacionados.

Figura 8: Coeficiente de correlação

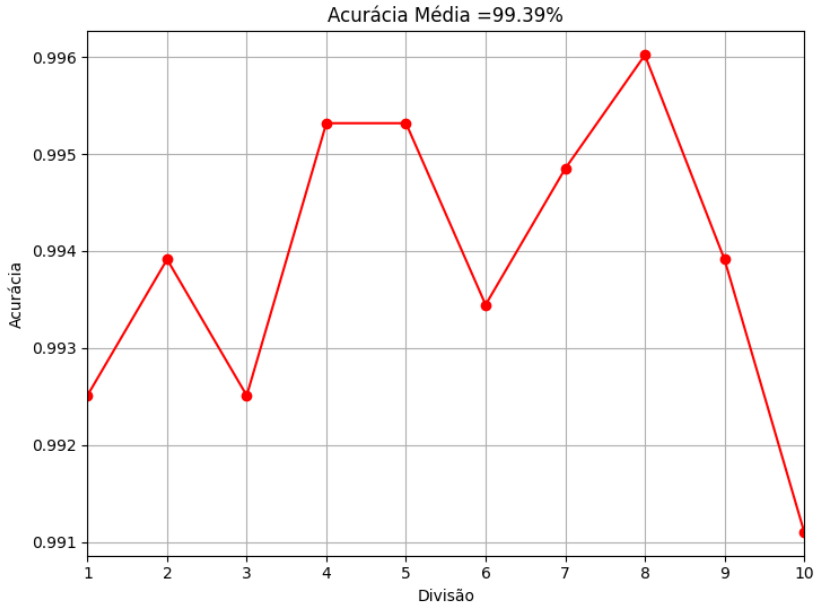


Fonte: O Autor (2025)

Tabela 3: Comparação dos melhores resultados com trabalhos relacionados

	Precisão	***Recall***	**F1 *score***	**Acurácia**
Correia *et al.* (32)	94%	97%	95%	95%
Souza (22)	99,7%	99,2%	99,4%	99,2%
Presente trabalho	99,58%	99,20%	99,39%	99,38%

Figura 9: Validação Cruzada sem os atributos A3, A5 e A10



Fonte: O Autor (2025)

8 Comparação de versões

Este capítulo é composto apenas pela seção 8.1, que tem por objetivo realizar uma análise sobre os resultados da primeira versão desenvolvida do projeto, comparando-os com os resultados descritos no presente trabalho sobre a versão mais atualizada do modelo.

8.1 Comparação da versão inicial com a versão atual

A primeira versão desenvolvida do presente trabalho, publicada no Simpósio Brasileiro em Segurança da Informação e de Sistemas Computacionais (SBSeg) em 2024 (9), obteve resultados interessantes, porém ainda não comparáveis com os vistos nos trabalhos relacionados.

Para a primeira versão, os seguintes hiperparâmetros foram definidos sobre o modelo:

- Árvores de decisão = 100 (n_estimators);
- Critério de homogeneidade = 'gini' (criterion);
- Número de recursos considerados na divisão = 'sqrt' (max_features);
- Bootstrap = True (bootstrap);
- Valor mínimo de impureza necessário para divisão do nó = 0.001 (min_impurity_decrease);
- Profundidade máxima da árvore = 10 (max_depth);
- Quantidade mínima de amostras para divisão = 10 (min_samples_split);
- Número mínimo de amostras em um nó folha = 4 (min_samples_leaf).

Essa escolha foi baseada em uma análise da possibilidade de *overfitting* no modelo. Os resultados obtidos nesta versão inicial são apresentados na Tabela 4.

Tabela 4: Resultados obtidos na primeira versão da ferramenta

	Precisão	***Recall***	**Acurácia**	**F1 *score***
Resultado	99.02%	96.04%	97.81%	97.50%

Entretanto, após a finalização desta primeira versão, foi verificado que esta obteve resultados menos satisfatórios comparados com aqueles identificados em trabalhos relacionados estudados. Diante disso, identificou-se a necessidade de revisar e aprimorar o modelo para alcançar um desempenho mais alinhado às expectativas e aos resultados estudados.

Sendo assim, foi iniciado um novo processo de testes sobre os hiperparâmetros a fim de identificar uma configuração que pudesse aprimorar os resultados, melhorando as métricas obtidas e a

classificação executada pelo modelo. Esse processo envolveu a exploração de diferentes combinações de hiperparâmetros e a aplicação de validação cruzada para assegurar que as melhorias fossem consistentes e generalizáveis.

Após a execução de diversos testes, chegou-se às configurações aqui apresentadas e aos resultados demonstrados. A Tabela 5 demonstra um comparativo das métricas obtidas na versão inicial (V1) (9) e na versão apresentada no presente trabalho (V2).

Tabela 5: Comparação dos resultados da V1 e V2 da ferramenta

	Precisão	***Recall***	**Acurácia**	**F1 *score***
Resultado V1	99,02%	96,04%	97,81%	97,50%
Resultado V2	99,58%	99,20%	99,39%	99,38%

A nova versão aqui apresentada demonstra uma melhora significativa em todas as métricas utilizadas para avaliação do modelo, isto devido às novas configurações definidas para o modelo *Random Forest* que incluem ajustes como a profundidade máxima das árvores, quantidade mínima de amostras para divisão, valor mínimo de impureza e número mínimo de amostras em um nó folha.

Essa melhoria reflete o progresso do projeto, demonstrando uma evolução desde o início do projeto até o presente trabalho. A versão atual (V2) supera a versão inicial em termos de métricas e também demonstra maior assertividade na classificação executada, o que é essencial para a aplicação prática do modelo em cenários reais.

9 Conclusão

Foi desenvolvida por meio deste trabalho uma ferramenta que faz uso do algoritmo *Random Forest* para realizar a identificação de possíveis sites de *phishing* acessados pelo usuário. A ferramenta elaborada executa análises automatizadas das páginas acessadas e promove alertas ao usuário sobre a segurança da navegação ou a possibilidade de a página ser maliciosa.

Os resultados obtidos com o modelo de aprendizado de máquina alcançaram precisão de 99,58%, recall de 99,2%, F1 Score de 99,39% e acurácia de 99,38%. Estes resultados, comparados com trabalhos relacionados apresentados ao longo do texto, são considerados satisfatórios, especialmente porque o presente trabalho utiliza uma base de dados bem mais ampla que em outros estudos.

Além disso, este trabalho partiu de uma versão inicial que, embora apresentasse resultados aceitáveis, ainda não se enquadravam com métricas vistas em trabalhos estudados. Por meio de testes e modificações nos hiperparâmetros do modelo, foi possível desenvolver uma versão final mais eficiente e com melhores resultados.

Os testes sobre o uso completo da ferramenta demonstram que ela funciona de forma satisfatória, podendo ser acessada por meio do Github em (35). Entretanto, o alerta que retorna ao usuário a mensagem sobre a classificação da página é um pop-up no formato “alert()“ do JavaScript, que surge na tela e obriga o usuário a clicar no botão de confirmação toda vez para continuar sua navegação.. Em trabalhos futuros, é importante implementar um alerta que não interrompa a navegação do usuário, garantindo uma melhor experiência no uso da ferramenta.

Também em trabalhos futuros poderiam ser realizados testes aprofundados sobre o tempo de retorno da ferramenta, além do consumo de CPU e memória para classificação. Isso permitiria observar o impacto na demora de resposta sobre os resultados e identificar as possibilidades de melhoria sobre esse tempo e sobre o consumo de recursos.

REFERÊNCIAS

1 SULLIVAN, B. **Phishing costs have tripled since 2015**. Disponível em https://ponemonsullivanreport.com/2021/08/. Acessado em janeiro de 2025.

2 PRANGGONO, B.; ARABO, A. Covid-19 pandemic cybersecurity issues. **Internet Technology Letters**, 2020.

3 KAMAL CARYN CHUAH YI YEN, M. H. P. A. H. A.; ZAHRA., F. Cybersecurity issues and challenges during covid-19 pandemic. **Preprints.org**, 2020.

4 ISPAHANY, J.; ISLAM, R. Detecting malicious urls of covid-19 pandemic using ml technologies. **Preprints.org**, 2020.

5 Cisco Systems, Inc. **PhishTank**. Disponível em https://phishtank.org/. Acessado em maio de 2024.

6 OPENPHISH. **OpenPhish**. Disponível em https://openphish.com/. Acessado em maio de 2024.

7 Moz, Inc. **The Moz Top 500 Websites**. Disponível em https://moz.com/top500. Acessado em junho de 2024.

8 Hudson, Tom. **Wayback Urls**. Disponível em https://github.com/tomnomnom/waybackurls. Acessado em junho de 2024.

9 GUARIZI, B. D.; MASCARENHAS, D. M. Identificação de ataques de phishing através de machine learning. In: **Anais Estendidos do XXIV Simpósio Brasileiro em Segurança da Informação e de Sistemas Computacionais**. [S.l.]: SBC, 2024.

10 STALLINGS, W. **Redes e sistemas de comunicação de dados: teorias e aplicações corporativas**. [S.l.]: 5 ed. Rio de Janeiro: Elsevier, 2005.

11 SILVA, A. L. de S.; SILVA, R. C. M. F. Protocolo http x protocolo https. **Nucleus 6.1**, 2009.

12 DOMCOP. **Open PageRank**. Disponível em https://www.domcop.com/openpagerank/what-is-openpagerank. Acessado em Fevereiro de 2025.

13 ISO. **ISO/IEC 27000:2018**. Disponível em https://www.iso.org/standard/73906.html. Acessado em Janeiro de 2025.

14 MITNICK, K.; SIMON, W. **A arte de enganar**. [S.l.]: Pearson Education, 2002.

15 ARAÚJO, E. E. A vulnerabilidade humana na segurança da informação. **Faculdade de Ciências Aplicadas de Minas**, 2005.

16 OLIVO, C. Avaliação de características para detecção de phishing de email. **ontifícia Universidade Católica do Paraná**, 2010.

17 NADEEM, M. et al. Phishing attack, its detections and prevention techniques. **STM JOURNALS**, 2023.

18 APWG. **Phishing Activity Trends Report, 3rd Quarter 2024**. Disponível em https://docs.apwg.org/reports/apwg_trends_report_q3_2024.pdf. Acessado em janeiro de 2025.

19 LI, D.; CHEN, Q.; WANG, L. Phishing attacks: Detection and prevention techniques. **Journal of Industrial Engineering and Applied Science**, 2024.

20 GOMES, D. d. S. **Inteligência Artificial: conceitos e aplicações**. [S.l.]: Revista Olhar Científico 1.2, 2010.

21 CERRI, R.; FERREIRA, A. C. P. de L. Aprendizado de máquina: breve introdução e aplicações. **Cadernos de Ciência Tecnologia**, 2019.

22 SOUZA, J. A. Detecção de ataques de phishing em tempo real utilizando algoritmos de aprendizado de máquina. In: **CEFET/RJ Campus Petrópolis**. [S.l.]: Trabalho de conclusão de curso (Bacharelado em Engenharia da Computação), 2023.

23 MARSLAND, S. **Machine Learning An Algorithmic Perspective**. [S.l.]: CRC Press, 2015.

24 LIMA, T. P. F. et al. **Previsão de óbito e importância de características clínicas em idosos com COVID19 utilizando o Algoritmo Random Forest**. [S.l.]: Instituto de Medicina Integral, 2021.

25 TANGIRALA, S. **Evaluating the Impact of GINI Index and Information Gain on Classification using Decision Tree Classifier Algorithm**. [S.l.]: International Journal of Advanced Computer Science and Applications, 2020.

26 OSHIRO, T. M.; PEREZ, P. S.; BARANAUSKAS, J. A. How many trees in a random forest? **Reasearch Gate**, 2012.

27 RIGATTI, S. J. Random forest. **Journal os Insurance Medicine**, 2017.

28 DIETTERICH, T. Overfitting and undercomputing in machine learning. **ACM computing surveys (CSUR)**, 1995.

29 SAFI, A.; SINGH, S. A systematic literature review on phishing website detection techniques. In: **Journal of King Saud University-Computer and Information Sciences**. [S.l.: s.n.], 2023. p. 590–611.

30 RODRIGUES, L. F. D. F.; BASTOS, I. A. M. D. M. Um sistema inteligente para prevenção de ataques phishing. In: . [S.l.]: Trabalho de conclusão de curso (Bacharelado em Engenharia de Redes de Comunicação), 2018. Universidade de Brasília.

31 CUNHA, F. F. do R. Detecção de phishing em páginas web. In: . [S.l.]: Programa Institucional de Bolsas de Iniciação Científica, 2011. Universidade Federal do Amazonas.

32 CORREIA, P. H. B.; PEDRINI, H. Detecção de domínios maliciosos baseada em técnicas de aprendizado de máquina. In: . [S.l.]: Trabalho de conclusão de curso (Bacharelado em Ciência da Computação), 2020. Universidade Estadual de Campinas.

33 Moz, Inc. **Domain Authority: What is it and how is it calculated**. Disponível em https://moz.com/learn/seo/domain-authority. Acessado em janeiro de 2025.

34 KRAMER, O.; KRAMER, O. Scikit-learn. **Machine learning for evolution strategies**, Springer, p. 45–53, 2016.

35 GUARIZI, B. D.; MASCARENHAS, D. M. **FindPhishing**. 2024. Disponível em https://github.com/bguarizi/findphishing/. Acessado em Janeiro de 2025.